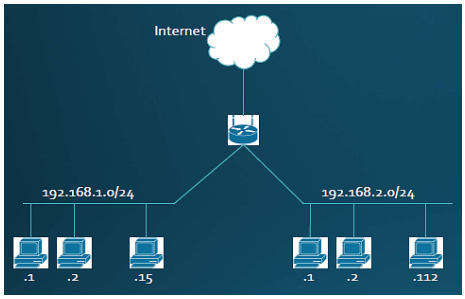
Progettazione di Architetture Firewall

- **Scegliere l'architettura di riferimento** (screening router, dual-homed, screened host o screened subnet?): scegliere la più semplice ed economica tra quelle che ci permettono di raggiungere il livello di sicurezza appropriato.
- **Scegliere i dispositivi** (security control) **più adeguati:** rispettare come minimo i requisiti, cercando di migliorare la flessibilità e la sicurezza e minimizzando i costi. Si ricorda che l'architettura di riferimento scelta è solo un punto di partenza, i dispositivi possono essere cambiati/modificati.
  - **(Static) packet filter** (praticamente mai utilizzato)
  - **Stateful (dynamic) packet filter**
  - **Circuit-level gateway/proxy**
  - **Layer-7 Filter o Application-Level gateway/proxy**
- **Configurare i dispositivi:** scrivere le regole per ognuno dei dispositivi scegliendo (default privacy e regole di autorizzazione).
- **Proporre come migliorare la sicurezza** (ad esempio, proporre inspection di comunicazioni web, aggiungere autenticazione utenti, monitoring).

1) Esercizio



Requisiti

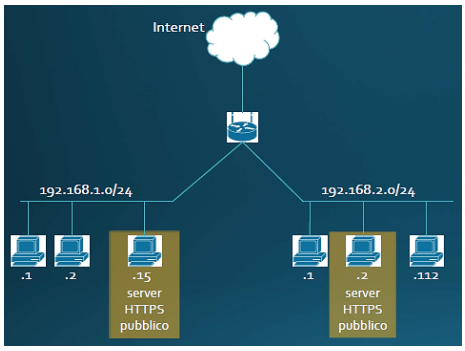
1. nessuna restrizione interna per entrambe le sottoreti
2. il server interno 192.168.1.1 deve essere raggiungibile dalla sottorete 192.168.2.0
3. il server interno 192.168.2.3 deve essere raggiungibile dalla sottorete 192.168.1.0
4. tutti gli host di entrambe le reti possono raggiungere Internet durante la pausa pranzo (13:00-14:00) e dopo le 18:00 senza restrizioni
5. esiste una lista di siti web che devono essere raggiungibili sempre perché necessari per lavorare (es. cloud aziendale)
6. la rete interna non deve essere raggiungibile dall'esterno
7. nient'altro deve essere permesso

Analisi

- **Architettura di riferimento**:
  - **Screening Router:** SI, perché non essendo presenta una elevata criticità a livello di sicurezza (non sembra un'azienda particolarmente sotto attacco) può risultare comodo accorpare il router con il gateway per risparmiare (soldi e costi di gestione).
  - **Dual-Homed:** SI**,** perché in questo modo chi deve raggiungere l'interno deve per forza di cosa superare il gateway (privilegia la sicurezza).
  - **Screened Host:** SI, perché alcuni siti web devono essere sempre raggiungibili; quindi, sullo screening router è possibile già far passare quei servizi (lascia una scorciatoia per possibili attaccanti però risparmia sul gateway).
  - **Screened Subnet:** NO, perché non ci sono "zone" che richiedono maggiore sicurezza e quindi non conviene spendere soldi inutilmente.

- **Dispositivi scelti**:
  - **Dual-Homed:** all'esterno uno **screened router** (packet filter) che semplicemente controlla che nessuno entri all'interno della rete. All'interno un **layer-7 filter** è abbastanza per filtrare le richieste a livello applicativo (siti web raggiungibili) perché non è richiesto autenticare gli utenti (in quel caso sarebbe necessario un application level gateway). Essendo gli indirizzi IP interni privati è necessario anche un NAT, il quale può essere inserito o nel router di bordo oppure nel gateway.
  - **Screened Host:** all'esterno si utilizza un **layer-7 filter** per sfruttare la scorciatoia e un **packet filter** internamente oppure utilizzare un doppio gateway. Con l'analisi dei dispositivi ci si accorge che questa soluzione non è preferibile in quanto non c'è un grande guadagno dato che dalla scorciatoia passano poche richieste (solo quelle sul tempo, le URL vanno comunque inviate al gateway).
  - **Screening Router:** si utilizza un **layer-7 filter**.
- **Configurazione Firewall (considerando l'architettura Screening Router)**:
  1. (req2) IP sorgente = 192.168.2.0/24, IP destinazione = 192.168.1.1 → ALLOW
     - IP sorgente = 192.168.1.1, IP destinazione = 192.168.2.0/24, SYN=true → DENY
     - IP sorgente = 192.168.1.1, IP destinazione = 192.168.2.0/24 → ALLOW
  2. (req3) IP sorgente = 192.168.1.0/24, IP destinazione = 192.168.2.3 → ALLOW
  3. (req4) Time = 13-14, 18-24, IP sorgente = 192.168.1.0/24 U 192.168.2.0/24, IP destinazione = NOT(192.168.1.0/24 U 192.168.2.0/24) → ALLOW
  4. (req5) IP sorgente = 192.168.1.0/24 U 192.168.2.0/24, URL = www.corporate-cloud.com U www.associate-company.it U www.servizio.it --> ALLOW
  5. (req7) DENY ALL
- **Miglioramenti**
  - Layer-7 filter avanzato che controlla anche le regole OWASP top 10
  - Proporre inspection di comunicazioni web
  - Aggiungere autenticazione utenti
  - Monitoring

2) Esercizio



Requisiti

1. nessuna restrizione interna per entrambe le sottoreti
2. il server interno 192.168.1.1 deve essere raggiungibile dalla sottorete 192.168.2.0
3. il server interno 192.168.2.3 deve essere raggiungibile dalla sottorete 192.168.1.0
4. tutti gli host di entrambe le reti possono raggiungere Internet durante la pausa pranzo (13:00-14:00) e dopo le 18:00 senza restrizioni
5. i server HTTPS pubblici devono essere raggiungibili da tutti gli interni e anche da internet
6. esiste una lista di siti web che devono essere raggiungibili sempre perché necessari per lavorare (es. cloud aziendale)
7. nient'altro deve essere permesso

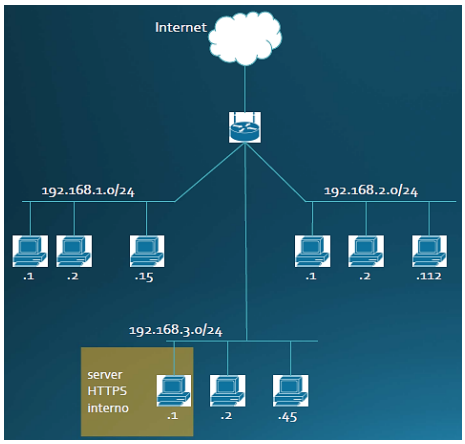
Analisi

- **Architettura di riferimento**:
  - **Screened Subnet:** perché così possiamo mettere i server in DMZ per evitare la propagazione di danni in caso di attacco. In particolare, si decide di utilizzare la versione con un unico dispositivo (firewall a quattro gambe in questo caso) il quale sebbene sia meno affidabile dell'altra alternativa (che usa tre dispositivi) consente di ridurre i costi (meno costi di gestione e meno dispositivi da comprare).
- **Dispositivi scelti**:
  - **Layer-7 Filter**
- **Configurazione Firewall Stateful**:
  1. Connessioni stabilite -> ALLOW
  2. IPdest = 192.168.3.1 U 192.168.3.2, Porta destinazione = 443 --> ALLOW
  3. IP sorgente = 192.168.2.0/24, IP destinazione = 192.168.1.1 → ALLOW
  4. IP sorgente = 192.168.1.0/24, IP destinazione = 192.168.2.3 → ALLOW
  5. Time = 13-14, 18-24, IP sorgente = 192.168.1.0/24 U 192.168.2.0/24, IP destinazione = NOT(192.168.1.0/24 U 192.168.2.0/24) → ALLOW
  6. IP sorgente = 192.168.1.0/24 U 192.168.2.0/24, URL = www.corporate-cloud.com U www.associate-company.it U www.servizio.it --> ALLOW
  7. DENY ALL
- **Miglioramenti**
  - Come esercizio 1

Commentato [LL1]: Quelle che hanno completato il 3-way handshake

Commentato [LL2]: I due server HTTPS pubblici sono posti in una nuova sottorete (la DMZ)

3) Esercizio



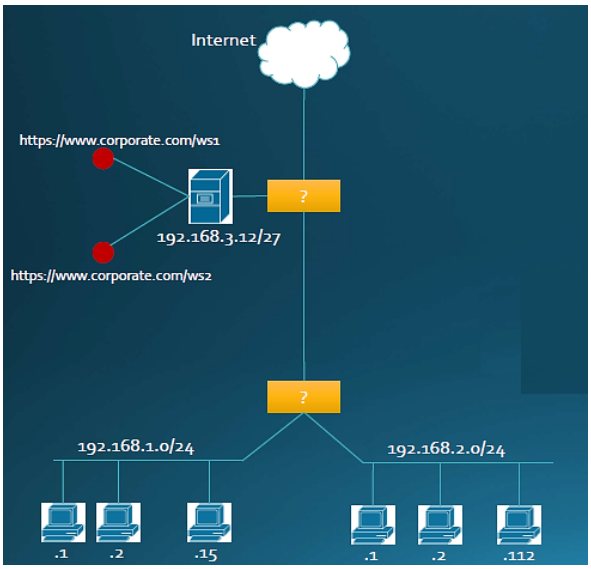
Requisiti

1. nessuna restrizione interna per entrambe le sottoreti
2. il server interno 192.168.1.1 deve essere raggiungibile dalle sottoreti .2 e .3
3. il server interno 192.168.2.3 deve essere raggiungibile dalla sottoreti .1 e .3
4. tutti gli host interni delle sottoreti .1 e .2 possono raggiungere internet durante la pausa pranzo
5. gli host della sottorete .3 non possono raggiungere internet
6. il server HTTPS sul 192.168.3,1 deve essere raggiungibile da tutti gli host interni
7. nessun altro host della rete .3 deve essere raggiungibile dalle sottoreti .1 e .2
8. nessuna rete interna deve essere raggiungibile dall'esterno

Analisi

- **Architettura di riferimento**:
  - **Screened Subnet:** perché la DMZ potrebbe essere applicata (non è chiaro se le sottoreti hanno lo stesso livello di sicurezza o meno). A quel punto si verrebbe a creare un firewall a 5 gambe.
  - **Dual homed**
  - **Screening router**
- **Dispositivi scelti**:
  - Nella dual homed si possono utilizzare uno **screened router** e un **gateway**.
  - Nello screening router basta un unico **packet filter stateful**.
- **Configurazione Firewall**:
  - *skippata*
- **Miglioramenti**
  - *Non trattati…*

4) Esercizio D'esame



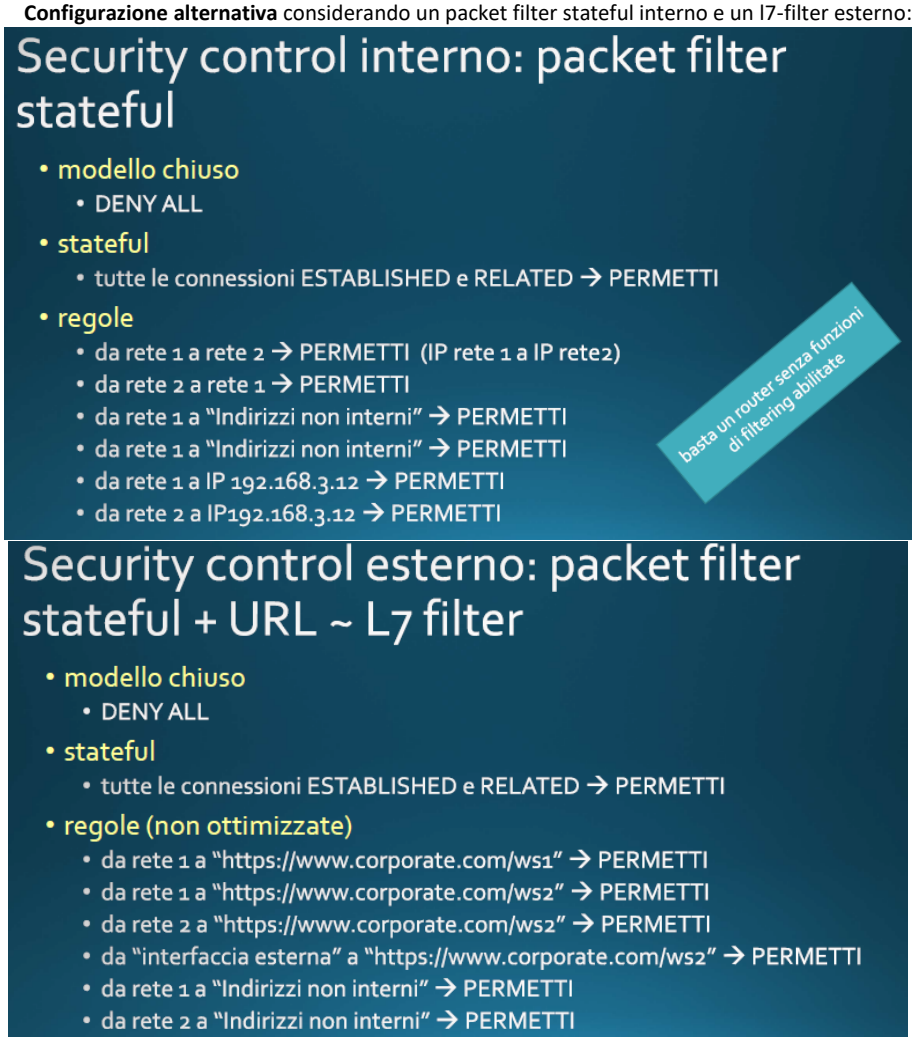
Requisiti

1. Rete interna .1 raggiunge web service 1
2. Rete interna .1 e .2 raggiungono web service 2
3. Web service 2 raggiungibile da internet
4. Rete interna 1 raggiunge rete interna 2 e viceversa
5. Rete interna 1 e 2 raggiungono internet
6. Tutto il reto non è consentito

Analisi

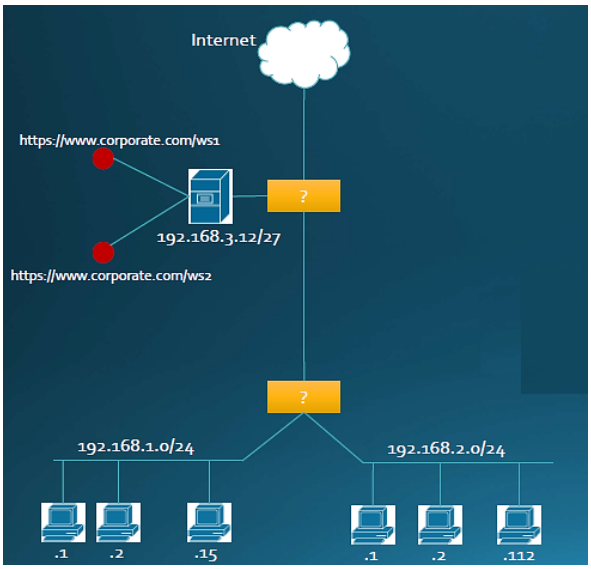
- **Architettura di riferimento**:
  - **Screened subnet**: perché ci sono servizi raggiungibili da internet
- **Dispositivi scelti**:
  - Internamente un **layer 7 filter** ed esternamente un **layer 7 filter**. In questo caso di decide di alleggerire il carico di richieste del filtro esterno, applicando dei filtri già all'interno. Una soluzione alternativa era quella di filtrare tutto ciò che includeva le URL nel layer 7 filter esterno e avere solo un packet filter stateful internamente per le altre regole.
- **Configurazione Firewall Esterno (l7 filter)**:
  1. (req2 e req3) d=/ws2 -> ALLOW
  2. (req1) IP sorgente 192.168.1.0/24, d=/ws1 -> ALLOW
  3. (req5) IP sorgente .1 U.2, IP destinazione NOT (.1 U .2 U .3) -> ALLOW
  4. DENY ALL
- **Configurazione Firewall Interno (l7 filter):**
  1. (req5) IP sorgente .1 U.2, IP destinazione NOT (.1 U .2 U .3) -> ALLOW
  2. (req2 e req3) d=/ws2 -> ALLOW
  3. (req1) 192.168.1.0/24, d=/ws1 -> ALLOW
  4. (req4) IP sorgente 192.168.1.0/24, IP destinazione 192.168.2.0/24 -> ALLOW
  5. (req4) IP sorgente 192.168.2.0/24, IP destinazione 192.168.1.0/24 -> ALLOW
  6. DENY ALL

- **Configurazione alternativa** considerando un packet filter stateful interno e un l7-filter esterno:



- **Miglioramenti**
  - *Non trattati…*

5) Esercizio D'esame



Requisiti

1. Rete interna 1 e 2 raggiungono web service 2
2. Web service 2 raggiungibile da internet
3. Rete interna .1 raggiunge rete interna .2 e viceversa
4. Utenti selezionati dalla rete interna 1 raggiungono web service 1
5. Tutti gli utenti della rete 1 e della rete 2 devono autenticarsi prima di raggiungere internet
6. Tutto il resto non è consentito

Analisi

- **Architettura di riferimento**:
  - Come esercizio 4
- **Dispositivi scelti**:
  - Per il router esterno si utilizza un gateway per permettere l'autenticazione degli utenti e quello interno è un l7-filter. Oppure, si può mettere il gateway internamente per effettuare l'autenticazione direttamente nel router interno.
- **Configurazione Firewall:**
  - Scegliendo di mettere il gateway internamente la configurazione del router esterno rimane quella dell'esercizio 4, mentre in quello interno bisogna solo modificare le regole per fare in modo che solo gli utenti autenticati raggiungano internet e che solo gli utenti presenti in una lista possano raggiungere il web service 1.
- **Miglioramenti**
  - *Non trattati…*